키스트로크 다이나믹스를 활용한 적응형 위험 기반 인증 시스템

신지안*, 이상협*, 이승현*, 이일현*, 이광재*
상명대학교 정보보안공학과*

An Adaptive Risk-based Authentication System using keystroke Dynamics Biometrics

Ji-Ahn Shin*, Sang-Hyeop Lee*, Seung-Hyeon Lee*, Il-Hyun Lee*, Kwangjae Lee*
Dept. of Information Security Engineering, Sangmyung University*

Abstract - 크리덴셜 스터핑은 다른 곳에서 유출된 아이디와 비밀번호로 정보를 탈취하는 수법이다. 이를 방어하기 위해서 다중 인증방식을 사용해야 하지만 대부분 사용자는 다중 인증방식이 있음에도 불구하고 그 존재를 모르거나 번거롭다는 이유로 그 기능을 사용하지 않는다. 이에 본 논문에서는 편리성과 보안성을 모두 갖춘 키스트로크 다이나믹스를 활용한 적응형 위험 기반 인증 시스템을 본 논문에서 제안한다. 사용자 인증을 위해 행위기반 생체인증 방식의 하나인 Keystroke 인증과 사용자의 환경정보를 확인하여 인증하는 방식인 A-RBA를 사용하여 두 인증을 모두 통과하여야 최종 인증을 결정한다. 머신러닝 평가 결과는 One-Class SVM을 사용하는 Keystroke 인증은 FAR, FRR이 각각 0.21, 0.04를 얻었고, KNN을 사용하는 A-RBA는 Accuracy, Recall, Precision, F1 Score, CVAA가 각각 98.2%, 98.1%, 98.1%, 98.1%, 99.4%를 얻었다. 또한, 다른 머신러닝 알고리즘을 비교하여 그 우수성을 확인하였다. 본 논문에서 제안한 시스템은 사용자의 편리성과 더불어 계속해서 새롭게 나타나는 해킹 공격을 극복하기에 좋은 참고연구가 될 것이다.

1. 서 론

크리덴셜 스터핑은 다른 곳에서 유출된 아이디와 비밀번호 등의 로그인 정보를 다른 웹 사이트나 앱에 무작위로 대입해 로그인이 이뤄지면 타인의 정보를 유출시키는 수법을 말한다. 2018년 6월 23-27일, 우리은행에서 사이버 공격이 발생했는데 공격자는 앞서 타 은행에서 유출된 고객정보를 이용해 56,000건 로그인에 성공했다고 한다. 이렇게 같은 아이디나 비밀번호를 여러 웹 서비스에 돌려 사용하게 되면 보안적으로 매우 치명적이라는 것을 알 수 있다.

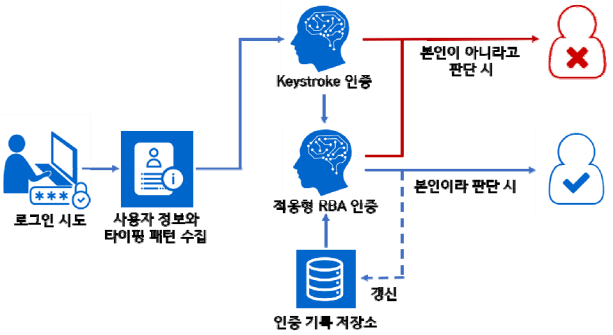
사용자 인증 방법으로는 하나의 인증방식만 사용하여 인증하는 것은 SFA(Single-Factor Authentication)라고 한다. 대부분의 웹 서비스는 지식기반 인증으로 SFA 방식을 사용한다. 이 방식은 사용자에게 있어 매우 편리하지만 앞서 언급한 크리덴셜 스터핑과 같은 공격에 취약하다. 그리하여 생겨난 것이 사용자 인증 3가지 방식 중 2가지 이상의 방식을 사용하는 MFA(Multi-Factor Authentication)이다. 이 방식은 ID, Password뿐만 아니라 OTP(One Time Password)나 지문 인식 등을 통해 다중으로 본인임을 인증하는 방식으로 보안성이 뛰어나다. 하지만 대부분 사용자는 다중 인증방식이 있음에도 불구하고 그 존재를 모르거나 번거롭다는 이유로 그 기능을 사용하지 않는다. 그렇기에 이러한 SFA 방식의 장점인 편리성과 MFA 방식의 장점인 보안성을 모두 갖춘 Keystroke Dynamics를 활용한 적응형 위험 기반 인증(A-RBA; Adaptive Risk-Based Authentication) 시스템을 본 논문에서 제안한다.

2. 시스템 구성

본 시스템은 Linux 운영체제를 기반으로 하여 Django를 통해 웹 서버, 머신러닝 서버, 데이터베이스를 구축한다. 사용자 인증을 위해 Keystroke 인증과 A-RBA를 사용하였다. Keystroke 인증은 로그인을 시도한 자가 정말 해당 사용자인지 판단하기 위해 사용한다. 또한, A-RBA는 사용자의 시공간, 환경정보를 확인하여 위험 평가를 한다.

Keystroke 인증은 사용자의 초기 10회의 키 입력 패턴을 후에 서술할 기법을 통해 수집하고 이를 분류하는데 기준으로 삼는다. 로그인 시도 시, 수집된 10회의 키 입력 패턴과 로그인 시 입력한 키 입력. 빠르기를 분석해서 평균보다 빠른 구간을 고주파수 영역, 느린 구간을 저주파수 영역으로 구분한다. 분류된 두 구간을 각각 비지도 머신러닝 모델인 One-Class SVM으로 범위에 벗어난 이상치를 감지하여 분류한다. 고주파수, 저주파수 영역에서 이상치가 하나라도 감지된다면 본인이 아니라고 판단하여 2차 인증을 요구한다.

A-RBA는 로그인 화면에서 사용자가 ID와 Password를 입력하여 로그인 성공하면 사용자의 시공간, 환경 정보(IP 주소, 국가, 도시, 운영체제, 브라우저, 해상도)를 수집하여 서버에 저장된다. 이 정보들은 각각의 사용자마다 엑셀 파일로 저장되며 로그인 성공할 때마다 정보가 추가되는 형식이다. 이렇게 여러 사용자의 데이터가 어느 정도 쌓이게 되면 로그인 시도를 할 시 저장되어있던 본인의 정보는 참값으로, 다른 사용자의 정보는 거짓 값으로 레이블링을 하여 머신러닝 모델을 학습시킨다. 학습 후 로그인 시도한 정보를 예측값으로 넣어 본인인지 아닌지 판단을 한다. 여기서 본인이라고 판단 시에는 로그인이 그대로 수행되는 것이고, 본인이 아니라고 판단 시에는 2차 인증을 요구한다.

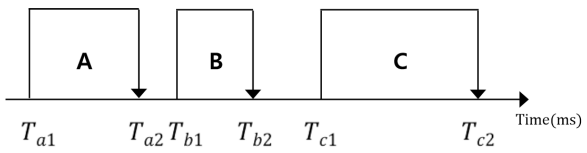


<그림 1> 제안하는 A-RBA 기반 인증 시스템 구성도

3. 제안하는 A-RBA 기반 인증 방법

3.1 Keystroke 인증

사용자의 키 입력 데이터를 수집하기 위해 Django 웹 프레임워크를 사용했고 Javascript를 이용하여 키 입력 값을 수집한다. 데이터셋을 생성하기 위해 10개의 사용자 타이핑 패턴 데이터를 얻어야 한다. 하지만, 사용자가 10번 로그인을 하는 동안 타이핑 리듬과 속도의 차이가 발생할 것이다. 이러한 문제는 전처리를 통해 해결한다. Javascript를 이용하여 Password 입력 시 생성되는 타이핑 데이터들을 얻는다. 사용자가 키보드를 누를 때 Key-Down 이벤트가 발생하고 눌렀던 키를 땠을 때 Key-Up 이벤트가 발생한다. 두 개의 키 입력 시각 값을 수집하여 다음과 같은 특성을 계산한다.



<그림 2> 키를 입력하는 동안 발생되는 키 이벤트

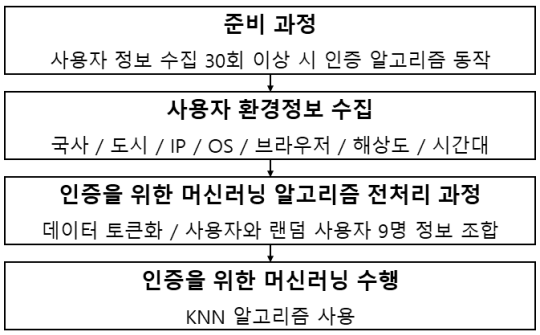
사용자가 'ABC'를 입력했을 때 A를 누른 시간(Key-Down)은 T_{a1}이고 A를 뗀 시간(Key-Up)은 T_{a2}이다. 이를 바탕으로 4개의 특성을 계산한다. Duration은 식 (1)과 같이 하나의 키의 지속 시간으로 $T_{a2} - T_{a1}$으로 계산할 수 있다. Interval은 식 (2)와 같이 연속된 두 키 AB의 A를 뗀 후부터 B를 누른 시각 차이로 AB의 간격으로 $T_{b1} - T_{a2}$로 계산한다. Latency는 AB 두 개 키를 눌렀을 때의 간격 또는 뗀 시각의 간격을 말한다. 각 $T_{b1} - T_{a1}$ 또는 $T_{b2} - T_{a2}$로 계산하며, 식 (3-4)와 같다. 사용자가 입력한 타이핑 데이터를 계산하여 나온 결과인 4개의 특성(Duration, Interval, Latency(Up-Up), Latency(Down-Down))을 기반으로 데이터셋을 생성한다.

$$Duration = (T_{a2} - T_{a1}) \quad (1)$$
$$Interval = (T_{b1} - T_{a1}) \quad (2)$$
$$Latency(Up-Up) = (T_{b2} - T_{a2}) \quad (3)$$
$$Latency(Down-Down) = (T_{b1} - T_{a1}) \quad (4)$$

사용자가 로그인하여 전처리를 통해 10개 샘플을 수집 후, 그 다음 로그인할 때 인증이 진행된다. 인증이 진행되기 위해 저장된 데이터는 정규화를 통해 특성을 고주파 또는 저주파로 나누게 된다. 정규화에 사용된 데이터는 학습에 영향을 미치지 않기 때문에 사용되지 않고 두 개의 특성으로 분류될 때만 사용된다. 학습은 비지도 학습으로 진행된다. 지도학습을 사용하기 위해서는 침입자 샘플이 필요하다. 소수의 침입자 역할 클래스를 사용하여 학습할 수 있지만, 침입자 샘플은 본인 제외한 어떤 것이든지 될 수 있어 침입자의 타이핑 패턴을 정확하게 나타낼 수 없다. 따라서 본 논문에서는 비지도 학습인 One-Class SVM을 사용하여 학습한다.

3.2 A-RBA

제안하는 A-RBA의 인증 방법은 그림 3과 같다. 먼저 사용자가 로그인에 성공하면 서버에 로그인 이력이 그림 4와 같이 각 사용자별 데이터베이스인 엑셀 파일에 저장된다. 로그인 이력의 요소들은 구글의 보안 경고 및 2차 인증을 요구하는 기준에 대한 요소들을 참고하여 만들었다[1]. 구글은 전에 로그인했던 정보와 현재 로그인 시도를 한 정보를 비교하여 보안 경고 메시지(로그인은 성공), 또는 2차 인증을 요구한다. 이러한 기준으로 사용되는 요소는 IP 주소, 국가, 사용자 에이전트 문자열(운영체제, 브라우저), 시간대, 언어, 해상도 등이다. 이를 참고해 본 시스템에서 사용하는 요소는 IP 주소, 국가, 도시, 운영체제, 브라우저, 해상도, 시간대이다. 시간대의 경우는 24시간 중 08-16시는 0, 17-21시는 1, 22-02시는 2, 03-07시는 3으로 나누어 값을 지정하였다[2]. 로그인 이력이 30개 미만일 경우는 사용자의 패턴으로 사용하기에 너무 적은 데이터라고 판단되어 머신러닝을 수행하지 않고 무조건 2차 인증을 요구하도록 제약 조건을 걸었다. 이후 데이터가 30개 이상 쌓이면 머신러닝 알고리즘이 동작한다. 알고리즘을 학습하기 위한 데이터로 참, 거짓 값을 1:1 비율로 사용한다. 예를 들어, A 사용자가 로그인 시도를 하며 서버에 로그인 이력이 100개 저장되어있다고 가정해보자. A 사용자의 이력 100개는 참값으로 레이블링한다. 그리고 A 사용자를 제외한 모든 다른 사용자 중에 9명의 사용자를 랜덤하게 뽑는다. 그 9명의 사용자의 로그인 이력들 중 100개를 랜덤하게 뽑아서 거짓 값으로 레이블링한다. 그렇게 총 200개의 데이터가 학습 및 검증 데이터셋으로 사용된다.



<그림 3> A-RBA 인증 방법

	A	B	C	D	E	F	G
1	country	display	os	browser	city	ip	time
2	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	0
3	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	0
4	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	0
5	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	0
6	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	2
7	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	2
8	KR	2560 x 1440	Windows 10	Chrome 83 (83.0.4103.61)	Asan	203.130.76.67	2

<그림 4> 로그인 이력이 저장되는 방식

4. 실 험 설 계

4.1 Keystroke 인증 실험설계

Keystroke 인증은 과거 여러 실험이 지속 연구돼왔지만, 대부분의 실험은 중대형의 데이터셋에 대한 분류에 초점을 두고 있다. 본 시스템 설계상 웹 사용자의 타이핑 패턴을 수집하는데 중대형 데이터셋을 수집해 사용하는 것은 적절치 않다고 판단했다. 따라서 사용자의 인증 모델을 생성하기 위해서는 10개의 인증 데이터가 필요하다. 10번의 로그인을 시도하여 데이터를 수집할 수 있지만, 사용자가 Password를 일관되지 않게 입력하는 경우가 많다. 한 번은 빠르게 입력하고 다음 입력 때에는 느리게 입력할 수 있다. 사용자의 타이핑 리듬에서 발생할 수 있는 편차로 이를 해결하지 않을 시 인증 성능이 크게 떨어질 것이다. 전처리를 통해 이상치(Outlier)를 제거하여 인증 성능을 향상한다. 따라서 수집한 10개의 샘플이 사용자의 타이핑 패턴을 나타내는지 확인해야 한다. 처음 5개의 샘플은 이상치를 탐지하기 위해 사용되는 실제 사용자 데이터로 가정한다.

처음 5개 샘플은 K-S 검정(K-S test; Kolmogorov-Smirnov statistic)을 사용하여 데이터를 수집한다. K-S 검정은 두 집단의 분포 유사성을 측정하는 방법으로 누적 분포 함수 간의 최대 거리(D)를 통계량으로 사용한다. 타이핑 데이터의 4개 특성(Duration, Interval, Latency (Up, Down)) 각각을 경험적 분포 함수로 정의하고 이를 통해 K-S 통계량은 식(5-7)로 정의할 수 있다. K-S 통계량은 두 개 데이터셋의 누적 분포 차이 최댓값으로 작을수록 두 분포는 유사하다 할 수 있다. 이를 기반으로 이후 5개의 샘플들은 처음 5개의 샘플과 유사한 경우에만 수집한다. 이때 K-최근접 이웃(KNN; K-Nearest Neighbor, KNN) 알고리즘을 사용하여 판단한다.

$$F_{K_R}(x) = \frac{1}{N_R}\sum_{i=1}^{N_R} I(X_i \le x) \quad (5)$$

$$F_{K_T}(x) = \frac{1}{N_T}\sum_{i=1}^{N_T} I(X_j \le x) \quad (6)$$

$$D_{K_R}|_{K_T} = sup_x|F_{K_R} - F_{K_T}| \quad (7)$$

사용자 타이핑 패턴의 식별을 성능 향상하기 위해 본 논문에서는 데이터셋을 2개의 특성으로 분리한다. 특성은 타이핑 시간 간격에 따라 각각 고주파 및 저주파로 분류한다. 같은 Password를 입력했을 때 사용자마다 문자 조합의 타이핑 속도가 다르다. 따라서 사용자의 두 가지 특성을 분리하면 사용자

패턴을 식별에 도움을 줄 것이다. 정규화에서는 Key-Up 값을 사용한다. 다음과 같은 방식으로 데이터셋을 정규화한다. 첫째, 첫 번째 키(Key-Up) 타이밍에 따라 모든 타이밍을 전환한다. 모든 키 타이밍을 첫 번째 타이밍과 비교하여 사용자가 늦게 입력하거나 빨리 입력했을 때 발생하는 편차를 해결한다. 둘째, 각 타이밍은 첫 번째와 마지막 타이밍까지의 총 지속 시간의 비율로 변환한다. 따라서 첫 번째 키 시각 값은 0이 되고 마지막 키 시각 값은 1이 될 것이다. 이러한 영역 차이를 통해 두 사용자를 시각적으로 구분하고 수학적으로 식별하는 것도 가능하다는 것을 알 수 있다. 고주파와 저주파를 구분하기 위해 임계값(Threshold)인 1/n을 만든다. 그 후 모든 두 개의 키 타이밍 차이에 대해 임계값보다 작으면 고주파 영역, 크면 저주파 영역으로 정한다.

4.2 A-RBA의 실험설계

본 실험 진행 시 참고할 실험이 존재하지 않아 가상의 시나리오로 사용자 정보를 만드는 과정이 요구되었다. 또한, A-RBA에서는 데이터셋을 만들고 실험함에 알고리즘을 바로 적용할 수 없어, 전처리 과정이 요구되었다. 머신러닝에 알고리즘을 사용할 때 문자가 아닌 수치로 나타내야 한다. 대표적으로 One-Hot Encoding을 사용하여 각 항목마다 컬럼을 부여하여 데이터를 수치로 매핑할 수 있지만, 본 실험에 사용할 데이터의 범위가 너무 넓어 불필요한 낭비가 발생하여 토큰화 방식의 전처리를 만들어 적용하였다.

사용자 데이터셋은 다양한 시나리오를 적용하여 로그인 이력을 만들었으며 총 13명의 가상 사용자를 만들었다. 예를 들어, 사용자 A는 집과 자취방을 오가며 로그인을 하는 대학생, 사용자 B는 직장과 집, 가끔 PC방에서 게임을 하며 취미생활을 즐기고 출장을 가기도 하는 직장인이다. 또한, 사용자 C는 맥북을 사용하며 집 앞 카페를 자주 이용하고 해외여행도 자주 가는 편인 사람이다. 이런 식으로 13명의 가상 사용자를 만들었으며 로그인 이력 또한 시나리오에 맞게 30개씩 생성하였다.

1	country	display	os	browser	city	ip	time
2	KR	1920 x 1080	Windows 10	Chrome 80 (80	Yongin-si	144.48.103.43	3
3	KR	1920 x 1080	Windows 10	Chrome 80 (8C	Yongin-si	144.48.103.43	3
4	KR	1920 x 1080	Windows 10	Chrome 80 (8C	Yongin-si	144.48.103.43	3
5	KR	1920 x 1080	Windows 10	Chrome 80 (8C	Yongin-si	144.48.103.43	2
6	KR	1920 x 1080	Windows 10	Chrome 80 (80.0.3987.132)	Yongin-si	144.48.103.43	2
7	KR	1600 x 900	Windows 8.1	Chr	Cheonan	27.0.231.32	2
8	KR	1600 x 900	Windows 8.1	Chr	Cheonan	27.0.231.32	2
9	KR	1600 x 900	Windows 8.1	Chr	Cheonan	27.0.231.32	3
10	KR	1600 x 900	Windows 8.1	Chro	Cheonan	27.0.231.32	3
11	KR	1920 x 1080	Windows 10	Chrome 80 (80.0.3987.132)	Yongin-si	144.48.103.43	2

집

자취방

(a) 사용자 A: 집과 자취방을 오가는 대학생

1	country	display	os	browser	city	ip	time
2	KR	1280 x 720	Windows 7	Microsoft Internet Explorer 11 (11.0)	Hanam-si	163.53.159.67	0
3	KR	1920 x 1080	Windows 10	Microsoft Internet	Soeul	45.113.51.200	1
4	KR	1280 x 720	Windows 7	Microsoft Internet	Hanam-si	163.53.159.67	0
5	KR	1920 x 1080	Windows 10	Microsoft Internet	Soeul	45.113.51.200	1
6	KR	1280 x 720	Windows 7	Microsoft Internet	Hanam-si	163.53.159.67	0
7	KR	1920 x 1080	Windows 10	Microsoft Internet Explorer 11 (11.0)	Soeul	45.113.51.200	1
8	KR	1280 x 720	Windows 7	Microsoft Internet Explorer 11 (11.0)	Hanam-si	163.53.159.67	0
9	KR	1920 x 1080	Windows 10	Chrome 83 (83.0.4103.61)	Soeul	45.113.51.200	1
10	KR	1280 x 720	Windows 7	Microsoft Inte	Hanam-si	163.53.159.67	0
11	KR	1920 x 1080	Windows 10	Microsoft In	Soeul	45.113.51.200	1
12	KR	1280 x 720	Windows 7	Microsoft In	Hanam-si	163.53.159.67	0
13	KR	1920 x 1080	Windows 10	Microsoft In	Soeul	45.113.51.200	1
14	KR	1280 x 720	Windows 7	Microsoft Internet Explorer 11 (11.0)	Hanam-si	163.53.159.67	0

출근

퇴근

(b) 사용자 B: 출, 퇴근하는 사무직 회사원

<그림 5> 시나리오를 적용하여 제작한 사용자 데이터셋

실험에 사용하는 데이터셋의 사용자 환경정보는 대부분 문자열이므로 숫자로 치환하여야 한다. 다행히도 각 요소가 모두 범주형 데이터이기 때문에 숫자와 1:1 매칭시킬 수 있다. 이런 방식을 사용하여 전처리 과정을 수행하였다. 사용자 A로 예상되는 사용자가 로그인에 성공하였을 때, 사용자 A를 제외한 모든 사용자 중 9명의 사용자(B-J)를 랜덤하게 뽑는다. 그리고 그 사용자 B-J의 데이터들을 불러와 Dataframe 타입의 변수에 넣은 후 사용자 A의 데이터(로그인 이력) 수 만큼 무작위로 뽑는다. 사용자 A의 데이터와 무작위로 뽑힌 데이터들을 Dataframe 타입의 변수에 넣는다. 그와 동시에 컬럼을 하나 더 추가하여 사용자 A의 데이터에는 참값 1로, 랜덤으로 뽑은 사용자 B-J의 데이터에는 거짓 값 0으로 정답 데이터를 추가한다. 이 과정을 수행하면 레이블링이 된 사용자 A-J의 로그인 이력이 문자열로 저장된다. 그리고 Dictionary 타입의 변수를 생성하여 컬럼마다 데이터를 읽어 중복 데이터를 제거한 후 넣는다. 이 변수에는 'Key : Value' 형식으로 되며 각 컬럼의 값들이 Key 값에 중복없이 들어가게 된다. 따라서 각 컬럼에 있는 개수대로 1부터 매핑 시켜주면 데이터 전처리를 위한 매핑 정보가 완성된다. 이러한 전처리 과정을 거치면 기존에 없던 새로운 국가, 도시, IP 주소 등이 들어오게 되어도 문제없이 그림 6과 같이 간단한 숫자로 매핑 시킬 수 있게 된다.

	country	display	os	browser	city	ip	time	result
0	KR	2560×1440	Windows 10	Chrome 83	Asan	230.103.67.76	0	1
1	KR	2560×1440	Windows 10	Chrome 83	Asan	230.103.67.76	0	1
2	KR	2560×1440	Windows 10	Chrome 83	Asan	230.103.67.76	2	1
3	KR	2560×1440	Windows 10	Chrome 83	Asan	230.103.67.76	1	1
.	.	.	.	.	.	.	.	
.	.	.	.	.	.	.	.	
.	.	.	.	.	.	.	.	
56	KR	1920×1080	Windows 10	Chrome 80	Youngin-si	144.48.103.43	3	0
57	KR	1600×900	Windows 8.1	Chrome 80	Cheonan	27.0.231.32	2	0
58	JP	1920×1080	Windows 10	Chrome 83	Osaka	72.33.4.21	1	0
59	US	2560×1440	Windows 7	IE 11	San Francisco	45.112.51.200	3	0

(a) 레이블링 된 사용자들의 로그인 이력을 문자열로 저장

{'KR' : 1, 'JP': 2, 'US' : 3}

{'2560×1440' : 1, '1920×1080' : 2, '1600×900' : 3}

{'Windows 10' : 1, 'Windows 8.1' : 2, · · ·, 'Windows 7' : 5}

{'Chrome 83' : 1, 'Chrome 80' : 2, 'IE 11' : 3}

{'Asan' : 1, 'Yongin-si' : 2, · · ·, 'Osaka' : 6, 'San Francisco' : 7}

{'230.103.67.76' : 1, · · ·, '144.48.103.43' : 9, '27.0.231.32' : 10, '72.33.4.21' : 11, '45.112.51.200' : 12}

(b) Dictionary 타입변수에 저장

	country	display	os	browser	city	ip	time	result
0	1	1	1	1	1	1	0	1
1	1	1	1	1	1	1	0	1
2	1	1	1	1	1	1	2	1
3	1	1	1	1	1	1	1	1
.	.	.	.	.	.	.	.	
.	.	.	.	.	.	.	.	
.	.	.	.	.	.	.	.	
56	1	2	1	2	2	9	3	0
57	1	3	2	2	5	10	2	0
58	2	2	1	1	6	11	1	0
59	3	1	5	3	7	12	3	0

(c) 사용자의 환경정보의 문자열을 숫자로 매핑

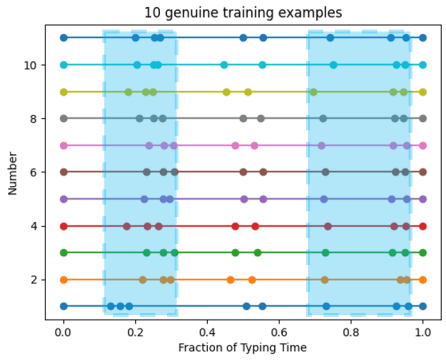
<그림 6> 머신러닝을 위한 전처리 과정

5. 실 험 결 과

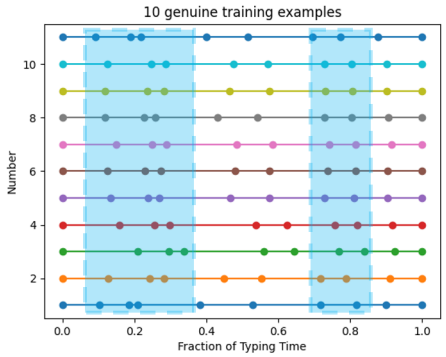
본 논문에서는 A-RBA와 Keystroke Dynamics 두 부분으로 나눠서 실험 결과를 예측한다. 두 부분의 예측 결과를 받은 후에 종합하여 최종 결과를 도출한다. A-RBA와 Keystroke Dynamics 둘 중 한 부분이라도 실패일 경우 타 사용자의 로그인 시도로 판단하여 2차 인증을 요구하고, 둘 다 성공일 경우에만 정상 사용자로 판단하여 로그인에 성공할 수 있다.

5.1 Keystroke Dynamics 실험 결과

결과를 평가하기 위해 사용자 9명과 그 중 한 명을 침입자로 가정하여 데이터를 수집하였다. 각 사용자들은 10번의 로그인을 통해 타이핑 패턴를 수집하여 사용자 인증을 한다. 생성된 데이터셋은 고주파와 저주파 두 개의 특성으로 나누고 두 개의 One-Class SVM 머신러닝을 통해 학습한다. One-Class SVM 머신러닝을 개선하기 위해 처음 입력되는 5개의 데이터를 K-S 검정을 통해 이상치를 제거했다. 다음은 같은 암호를 사용하여 두 사용자 타이핑 패턴 비율을 그래프로 나타냈다. 암호는 대문자, 소문자, 특수문자, 숫자를 이용한 'Star@@2048'이다.



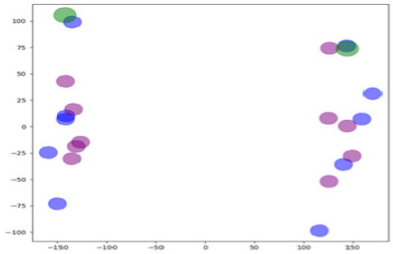
(a) 정상 사용자의 타이핑 패턴



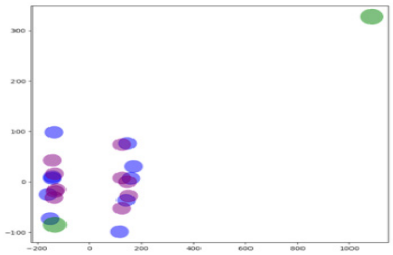
(b) 이상 사용자의 타이핑 패턴

<그림 7> 시간 간격으로 사용자별 타이핑 패턴의 식별

그림 7은 시간 간격으로 사용자별 타이핑 패턴을 기록한 그래프이다. 두 그래프를 비교하면 사용자가 확실히 구별되는 고주파 또는 저주파 영역이 있다. 그래프에서 't'와 'a', '2'와 '0'의 영역을 통해 사용자 간 차이가 보이고 나머지 부분은 비슷한 것을 알 수 있다. 이 두 개의 영역에서 두 번째 사용자는 첫 번째 사용자보다 넓은 영역이 있는 것을 보인다. 이 특성을 정확히 보기 위해서, 고/저주파로 표현한 타이핑 패턴 그래프로 확인하였다. 파란색 점은 고주파 데이터셋, 보라색 점은 저주파 데이터셋 그리고 초록색 점은 사용자 데이터이다. 그림 8의 (a)와 같이 정상 사용자 데이터는 데이터셋과 밀집된 것을 볼 수 있다. 하지만 그림 8의 (b)와 같이 타 사용자 로그인 시도에서는 타 사용자의 포인트가 데이터셋과 멀리 떨어져 있는 것을 볼 수 있다.



(a) 정상 사용자 로그인 시도



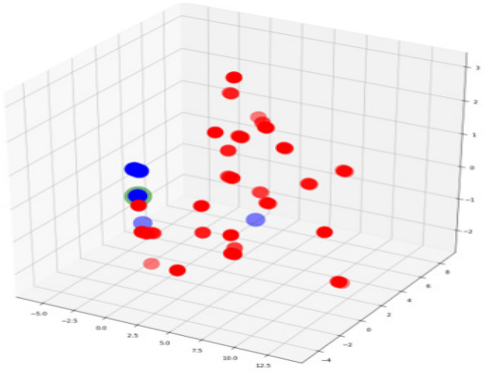
(b) 타 사용자 로그인 시도

<그림 8> 고/저주파로 표현한 타이핑 패턴 그래프

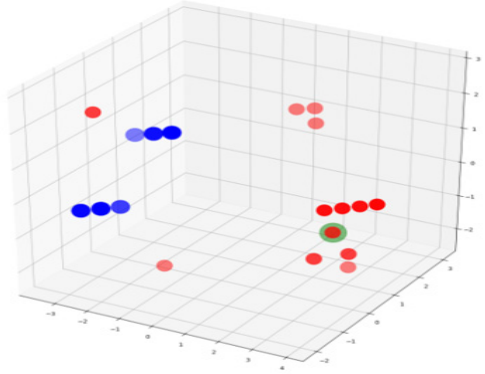
이 방법으로 침입자를 정상 사용자로 잘못 판단되는 오류율인 부정허용률(FAR; False acceptance rate)은 0.21, 정상 사용자가 침입자로 잘못 판단되는 오류율인 부정거부율(FRR; False rejection rate)은 0.04 결과를 얻었다. 인증 성능을 높이기 위해 사용자의 타이핑 패턴 변화를 능동적으로 갱신하거나 고주파, 저주파의 결정하는 임계값을 최적화 알고리즘을 통해 FAR과 FRR을 개선할 수 있을 것이다.

5.2 A-RBA 실험 결과

A-RBA에서 사용하는 데이터셋은 7개의 요소로 이루어져 있어 본래는 7차원이지만 시각적인 그래프로 나타내기 위하여 그림 9와 같이 3차원으로 축소해 나타내었다. 초록색 점은 사용자 로그인 시도, 파란색 점은 사용자 접속 기록, 붉은색 점은 타 사용자 접속 기록이다. 만일 초록색 점이 파란색 점과 겹친다면 정상 사용자의 로그인 성공 그래프이고, 초록색 점이 붉은색 점과 겹치거나 근처에 생긴다면 타 사용자의 로그인 시도 그래프이다. 정상 사용자 로그인 경우는 로그인 성공으로 판단하고, 타 사용자의 로그인 시도이면 2차 인증을 요구한다.



(a) KNN 알고리즘 정상 사용자 로그인 성공



(b) KNN 알고리즘 타 사용자 로그인 시도

<그림 9> A-RBA 실험 결과 그래프

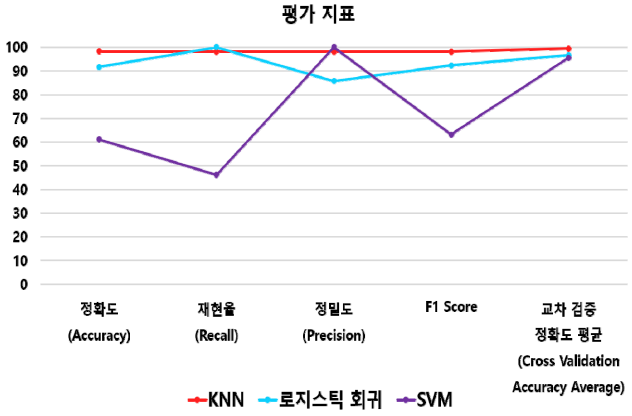
위 그림에서 KNN 알고리즘은 결과를 잘 예측한 것으로 볼 수 있지만, 보다 적합한 알고리즘을 선별하기 위해서 다른 분류 알고리즘과 성능 평가를 수행해 보았다. 표 1에서 표현한 것과 같이 KNN의 정확도(Accuracy)와 재현율(Recall), 정밀도(Precision), F1 Score 그리고 교차검증 정확도 평균(CVAA; Cross Validation Accuracy Average)가 98%대 이상으로 가장 높게 나왔다. 다음은 로지스틱 회귀(Logistic Regression)로 정확도는 91.6%, 재현율은 100%, 정밀도는 85.7%, F1 Score는 92.3% 그리고 교차검증 정확도 평균은 96.6%로 두 번째로 높게 나왔다. 마지막 SVM 알고리즘 경우 정밀도 100%와 교차검증 정확도 평균이 95.5%로 높은 퍼센트를 보여주지만, 정확도와 F1 Score에서 60%대, 재현율은 46.1%로 셋 중에 가장 낮게 나옴을

알 수 있다. 그림 10의 그래프를 보면 KNN 알고리즘이 가장 안정적으로 나온 것을 볼 수 있으며, 로지스틱 회귀와 SVM 알고리즘 경우에는 그래프의 높낮이가 나타남을 확인할 수 있다. 그리고 SVM 알고리즘 경우 결과의 과대 적합과 과소 적합을 피하면서 하이퍼 파라미터 변수인 C와 Gamma값을 적절히 선택해 주어야 하는 데 어려움이 있어서 본 시스템과는 적합하지 않다고 결정하였다. A-RBA 알고리즘 성능 평가 비교 결과 KNN 알고리즘이 가장 안정적이고 본 시스템에 적합하다고 판단되어 KNN 알고리즘을 최종 알고리즘으로 적용해 시스템을 개발하였다.

<표 1> A-RBA 알고리즘 성능평가

평가지표	KNN	Logistic Regression	SVM
정확도 (Accuracy)	98.2%	91.6%	61.1%
재현율 (Recall)	98.1%	100%	46.1%
정밀도 (Precision)	98.1%	85.7%	100%
F1 Score	98.1%	92.3%	63.1%
교차검증 정확도 평균 (CVAA*)	99.4%	96.6%	95.5%

*CVAA: Cross Validation Accuracy Average



<그림 10> A-RBA 알고리즘 성능평가 비교 그래프

4. 결 론

본 논문에서는 인증 시 사용자가 별도의 인증과정 없이 사용자의 패스워드 입력 패턴, 시 공간, 환경정보를 이용하여 SFA 방식의 편리성과 MFA 방식의 보안성을 모두 갖춘 Keystroke Dynamics를 활용한 적응형 위험 기반 인증 시스템을 개발하고자 하였다. 본 연구에서 Keystroke Dynamics는 패스워드 입력 패턴을 분석하여 로그인 시도자가 다른 사용자가 아닌지를 판별했다. 설계 시 웹 환경을 반영하여 소수의 데이터를 이용해야 했다. 이를 위해 데이터셋을 10개로 구성하였으며 이를 이용하여 비지도 학습으로 머신러닝 과정을 진행하였다. 적응형 위험 기반 인증 시스템은 로그인 시도자의 시공간, 환경정보를 분석하는 기법으로 설계 시 실제 상황을 적용하기 위해 중형 도시의 평범한 사무직과 대학생 등 여러 시나리오를 만들어 데이터셋을 구성하였다. 구성한 데이터셋을 지도학습으로 머신러닝 하였으며, 다양한 기계 학습 알고리즘을 비교 분석하여 성능을 평가하였다. Keystroke Dynamics를 활용한 적응형 위험 기반 인증 시스템은 새로운 시스템으로 사용자의 편리성과 더불어 계속해서 새롭게 나타나는 해킹 공격을 극복하기에 좋은 참고가 될 연구이다.

[참 고 문 헌]

[1] Wiefling, Stephan, Luigi Lo Iacono, and Markus Dürmuth. "Is this really you? An empirical study on risk-based authentication applied in the wild." *IFIP International Conference on ICT Systems Security and Privacy Protection*. Springer, Cham, 2019.

[2] Sepczuk, Mariusz, and Zbigniew Kotulski. "A new risk-based authentication management model oriented on user's experience." *Computers & Security* 73 (2018): 17-33.

[3] Raul, Nataasha, Royston D'mello, and Mandar Bhalerao. "Keystroke Dynamics Authentication Using Small Datasets." *International Conference on Security & Privacy*. Springer, Singapore, 2019.

[4] Kang, Pil-Sung, and Sung-Zoon Cho. "A Study on User Authentication based on Keystroke Dynamics of Long and Free Texts." *IE interfaces* 25.3 (2012): 290-299.

[5] 박기남. 머신 러닝 알고리즘을 이용한 네트워크 침입 탐지 시스템. 석사학위논문. 성균관대학교, 2019.

[6] 이종현. 머신러닝을 활용한 중학교 수학 기초학력 미달 비율 예측모형 탐색. 박사학위논문. 영남대학교, 2020.

[7] 오윤태. 로지스틱 회귀와 서포트벡터머신의 머신러닝 성능 비교 실험. 석사학위논문. 국민대학교, 2019.